

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

Requester information			
Requester Name:	<i>[To be completed by the MoD requester]</i>	General Department:	<i>[To be completed by the MoD requester]</i>
Email:	<i>[To be completed by the MoD requester]</i>	Section:	<i>[To be completed by the MoD requester]</i>
Phone Number/extension:	<i>[To be completed by the MoD requester]</i>	Force or BU:	<i>[To be completed by the MoD requester]</i>
Strategic Information (Filled By Project Owner)			
Initiative Name	<i>[To be completed by the Project Owner]</i>	Priority	<i>[To be completed by the Project Owner]</i>
Project Name, from Roadmap	<i>[To be completed by the Project Owner]</i>		
Components from To-Be Architecture Realized	<i>[To be completed by the Project Owner]</i>		
Screening Questions (Filled By Technology)			
Requirements/SRS/User Stories Defined and Approved		Yes/No/Comments	
Integration Requirements Defined and Approved		Yes/No/Comments	
Security Requirements Defined and Approved		Yes/No/Comments	
Uses approved Architecture/Design Methodology		Yes/No/Comments	
Architecture Constraints Documented		Yes/No/Comments	
Uses Approved Solution Stack (Hardware/Software)		Yes/No/Comments	
Is system described sufficiently (Section 1.1 to 1.3))		Yes/No/Comments	
Is solution design described sufficiently (Section 2.1 to 2.9)		Yes/No/Comments	
Is the Risk and Mitigation Strategies provided		Yes/No/Comments	
Document Completion Approved?		Yes/No/Comments	

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

Solution Architecture Section (Project Team)

Requirements and Constraints

BRD	The Business Requirements Document is delivered as a separate controlled document in Arabic and English editions, capturing the business objectives, scope, stakeholders and business requirements. It is complemented by the functional design specifications, one per module.
SRS/User Stories	The functional design specifications, one per module, and the product backlog. A per-page end-to-end test-case catalogue (Gherkin, 194 authored files) provides the executable acceptance criteria. A formally controlled software requirements specification is pending outstanding owner decisions.
Solution Requirements	Single-tenant event platform for the Saudi International Maritime Forum (RSNF): visitor registration and administrator approval; digital QR badge and gate access control; forum programme, sessions and seat booking; live session streaming, moderated Q&A and comments; exhibition, booths, sponsors and media partners; news, media gallery and past-edition archive; networking, contact sharing and speaker / delegation / business meetings; notifications; ratings and statistics; and a Control Panel for full event administration without a code release.
Integration Requirements	Internal applications: SMTP e-mail relay, Syslog / SIEM, a filesystem file store, and SQL Server 2022 (Standard in Development / Test; Enterprise in an AlwaysOn Availability Group for production). External (outbound only, via the controlled egress point): YouTube caption API, a server-to-server subtitle import that sends the public video id only. This is the sole outbound integration in the system. Artificial intelligence is not an external integration: no AI provider is enabled in the delivered configuration, so no AI request, session content or credential leaves the ministry network. Client-side: YouTube live playback, performed by the attendee device; the platform stores only the stream URL. Not integrated: Active Directory / LDAP. SIMF operates its own ASP.NET Core Identity store.
Security Requirements	Authentication: e-mail + password; second factor, e-mailed OTP (visitors) or TOTP authenticator (administrators) with single-use recovery codes; optional ES256 biometric device key on mobile.

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

	Authorization: role-based access control with per-page / per-action permissions baked into the JWT and enforced on both the API and the Control Panel; Administrator = wildcard. Encryption: TLS 1.2+ in transit; PII (national ID / Iqama / passport, mobile numbers) and identity-document images encrypted at rest with application-level AES-GCM (a 32-byte operator-supplied key via Storage:UserIdDocumentEncryptionKey; IPiiEncryptor). There is no dependency on database-native TDE. Hardening: WAF, multi-dimensional rate limiting, security headers and CSP, explicit CORS allow-list, upload scanning, secrets from environment variables with production boot guards. Audit: two append-only trails, OperationLog (security-relevant business events) and RowAudit (row-level before/after images). Compliance: aligned to the NCA Secure Application Development Standard (ECC / OWASP baselines).
Hosting Requirements	On-premises on Windows Server 2022, on the SITE Private Cloud, behind a load balancer and firewalls over SQL Server 2022. The three-zone network layout is in section 2.1.
Architecture Methodology or Best Practice used	Modular monolith with Domain-Driven Design layering (Domain, Application, Infrastructure, API). The network follows a defence-in-depth three-zone model (Internet, application-server zone, data zone) with a stateless, horizontally scaled application tier and a high-availability database.
Architecture Constraints	Frontend (public website + Control Panel), Backend API, Database. • Hard event deadline with a post-publish change freeze. • Mandatory NCA security compliance and source-code handover. • On-premises hosting; SQL Server 2022. Development and Test run a single node (decision O-3). Production runs the two database nodes of the customer server requirements workbook as an AlwaysOn Availability Group; the edition is confirmed with the site infrastructure team. • Two physically separate databases with no cross-database foreign keys, transactions or duplicated live data. • Arabic primary (RTL) and English secondary throughout.
Software Specification	.NET 10, FastEndpoints, FluentValidation, EF Core (code-first), Blazor Server + Blazor SSR, the shared SIMF.Components library over a single design-token stylesheet, Flutter (Dart) for iOS and Android, SQL Server 2022, IIS, Serilog, MailKit.

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

Hardware Specification	The authoritative hardware specification for this submission is the customer server requirements workbook, reproduced in the sizing table in section 2.1. Production: WEB 2 nodes, API 4 nodes and CP 2 nodes, each Windows Server 2022 with 32 GB RAM, 16 vCPU and 300 GB; Database 2 nodes, Windows Server 2022 with 64 GB RAM, 8 vCPU and 2 TB. Pre-production: one front-end node carrying WEB, API and CP (32 GB, 16 vCPU, 300 GB) and one database node carrying the databases and the file store (32 GB, 8 vCPU, 1000 GB). Every production row is marked Server + DR in the workbook.
------------------------	--

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

1.1 Purpose

This document describes the high-level design for the SIMF (Saudi International Maritime Forum) platform, delivered for the Royal Saudi Naval Forces (RSNF) under a Ministry of Defense programme.

1.2 System Overview

SIMF is a single-tenant event platform for the Saudi International Maritime Forum. It serves three audiences through three front-end applications that share one backend API and two databases. It is designed to:

- Register visitors online, verify their e-mail and identity, and route them through an administrator approval workflow.
- Issue each approved attendee a digital QR badge and control physical entry through gate scanning.
- Publish the forum programme and let attendees browse sessions, reserve seats and receive reminders.
- Stream live sessions (with a sign-language feed) and let attendees submit moderated questions and comments.
- Present the exhibition, booths, sponsors, media partners, news, media gallery and the past-edition archive.
- Enable networking, contact sharing, and speaker / delegation / business meeting requests.
- Give organisers a Control Panel to administer every aspect of the event without a code release.
- Collect ratings and feedback and present event statistics.

High-level assumptions and constraints

- The forum runs on fixed dates; the platform must be feature-complete and frozen before it opens, and an outage during the event cannot be rescheduled.
- Hosting is on-premises on the SITE Private Cloud; there is no public-cloud dependency.
- The system must comply with the NCA Secure Application Development Standard.
- Arabic is the primary language (right-to-left); English is secondary.
- Identity data and business data are held in two physically separate SQL Server databases with no cross-database foreign keys.
- The source code is contractually handed over to the customer.

1.3 System Context

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

Users

- Attendees / visitors / VIP delegates, use the mobile app (Android + iOS) and the public website to register, receive a digital badge, browse the programme, reserve seats, watch live sessions, ask questions, network and rate the event.
- Anonymous public, use the website to read public content (home, programme, visit information) and to begin registration.
- Administrators / organisers / scientific committee / public relations, use the Control Panel, reached on a separate hostname (the administrator is the "Backend user" in the SITE reference topology of section 2.1).
- Gate operators and session moderators, use the mobile app staff / moderator screens and the Control Panel.

External entities (outbound only, through the controlled egress point)

- No artificial-intelligence provider is enabled in the delivered configuration, so none is an active external entity. The AI endpoint is a configuration value, described under Internal systems below.
- YouTube caption API, server-to-server subtitle import that feeds the AI summary drafter (egress approval pending; the paste / upload path works without it).
- YouTube live playback, performed by the attendee device directly; this traffic does not traverse the SIMF backend.

No external entity initiates an inbound connection to SIMF.

Internal systems

- SMTP relay, transactional e-mail (verification codes, OTP, approval notices, alerts), queued and dispatched asynchronously.
- Syslog / SIEM, centralised structured logging.
- AI endpoint, serves the inference features (session minutes, question filtering, visitor assistance and translation). SIMF.Api is its only caller. It is a configuration value, and no provider is enabled in the delivered configuration, so no inference runs and no AI traffic is generated.
- File store, a filesystem store holding avatars, encrypted identity documents, VIP photos, session recordings, speaker presentations and media assets. Local to the API host in the single-node deployment; in the multi-node target it is a shared, clustered store (SMB) in the HSA zone, so any API node reads back what another wrote.
- SQL Server 2022, hosts the SIMF_Identity and SIMF_App databases. A single node in Development and Test (O-3); the two production nodes of the customer server requirements workbook run as an AlwaysOn Availability Group, with the edition confirmed with the site infrastructure team (see section 2.1).

SIMF does not integrate with Active Directory / LDAP; it operates its own ASP.NET Core Identity store.

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

2.1 Architecture Overview

SIMF is a modular monolith. One backend API serves the mobile app, the public website and the Control Panel over two separate databases, SIMF_Identity and SIMF_App. It is hosted on-premises on Windows Server 2022 with SQL Server 2022.

The architecture is built for the event-day load and uses a three-zone network model: an Internet zone, an application-server zone (SSA), and a data zone (HSA), with a firewall at each boundary. Figure 1 shows the layout.

Figure 1, SIMF production deployment and network architecture. One node per hosting server, with its zone, its specification and the protocol and port of every path. The diagram is reproduced at full page size on the landscape pages that follow section 2.3.

Internet. Attendees use the mobile app and the public website over HTTPS. Administrators use the Control Panel over HTTPS. SIMF makes an outbound call to one external service only: the YouTube caption API. No artificial-intelligence provider is enabled in the delivered configuration, so AI generates no traffic at all. Authentication uses e-mail one-time passwords, so there is no SMS or NAFATH dependency.

SSA Zone (application servers). A web application firewall and load balancer, in an active/standby pair, terminate TLS, filter traffic against the OWASP rule set, and balance requests across healthy nodes. Each application tier is scaled horizontally: the API tier (SIMF.Api, four stateless nodes) serving REST; the website tier (SIMF.Web, two nodes); and the admin tier (SIMF.ControlPanel, two nodes, with session affinity). The scheduled jobs (session reminders, seat-hold expiry, rating prompts, the daily NCA sweeps and the e-mail queue) are hosted services running in-process inside the API host, which is why the customer server requirements workbook carries no worker row. Moving them to a dedicated Windows Service is a later option, not part of this submission. The zone also holds the internal SMTP relay, the log collector, and the single controlled egress point for the two outbound calls. The website and the Control Panel reach data only through the API; only the API and the worker connect to the database.

HSA Zone (data). The database sits alone in the most protected zone. The customer server requirements workbook specifies two database nodes, marked Server + DR. The proposed realisation is SQL Server 2022 in an AlwaysOn Availability Group across those two nodes, a read-write primary and one replica reached through an availability-group listener, with synchronous commit and automatic failover. The edition and the quorum configuration are confirmed with the site infrastructure team. The zone also holds the shared file store, which keeps every uploaded file, including identity documents, encrypted at rest, and the scheduled backups. Only the application servers reach this zone.

Transport. Every connection uses HTTPS with TLS 1.2 or higher. TLS terminates at the load balancer and is re-encrypted to the backend.

Deployment sizing and capacity

SIMF runs a time-boxed event, so the design point is the event-day peak, not an average load. The platform is sized for about 30,000 concurrent attendees at peak, roughly 50,000 registered at a 0.6 peak factor, with headroom to about 40,000. Target response times at that load are 400 ms

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م				رمز النموذج Form Code
1	رقم النسخة Rev. Number			
إدارة التقنية	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer

for sign-in, 250 ms for a gate scan and 300 ms for a read, at under 75% CPU. Live-session video streams directly from YouTube to the attendee device and never passes through SIMF, so the servers carry the real-time channel and the REST traffic, not video. The per-tier sizing is below.

Tier / role	Zone	Instances	Spec (per node)	Purpose and sizing basis
WAF and load balancer	SSA edge	2 (active/standby)	not a row in the customer workbook	TLS termination, OWASP web-application-firewall filtering, layer-7 load balancing and health probes. Provided by the site network team.
API tier, SIMF.Api	SSA	4	Windows Server 2022, 32 GB RAM, 16 vCPU, 300 GB	Stateless REST for all three clients. Workbook row API, Server + DR. PBKDF2 password hashing is CPU-bound, which is what the vCPU count carries.
Website tier, SIMF.Web	SSA	2	Windows Server 2022, 32 GB RAM, 16 vCPU, 300 GB	Blazor SSR, public and read-heavy, served from cache with session affinity at the load balancer. Workbook row WEB, Server + DR.
Admin tier, SIMF.ControlPanel	SSA	2	Windows Server 2022, 32 GB RAM, 16 vCPU, 300 GB	Blazor Server, operator scale, sticky circuits. Workbook row CP, Server + DR.
Background jobs	SSA	no server of their own	hosted in the API tier above	The scheduled jobs are IHostedService instances inside SIMF.Api, so they consume the API tier's capacity and the workbook carries no worker row.
Database, SQL Server 2022	HSA	2	Windows Server 2022, 64 GB RAM, 8 vCPU, 2 TB	SIMF_Identity and SIMF_App. Workbook row Database, Server + DR, proposed as an AlwaysOn Availability Group across the pair.
Shared file store	HSA	on the database nodes	included in the 2 TB above	Stored files including encrypted identity documents. The workbook pairs the file store with the database node, noted DB + File.

- The workload is read-heavy and cacheable. Reads are served from a per-node in-memory cache, and the database handles writes and cache misses.
- The application tier is elastic. The API is stateless, so capacity is added by adding nodes; the website and Control Panel scale behind the load balancer with session affinity.
- Under overload the system degrades gracefully: rate limits and per-dependency circuit breakers return a clean 429 or 503 rather than failing.
- Pre-production, from the same workbook: one front-end node carrying WEB, API and CP together (Windows Server 2022, 32 GB RAM, 16 vCPU, 300 GB) and one database node carrying both databases and the file store (Windows Server 2022, 32 GB RAM, 8 vCPU, 1000 GB).

Key architectural principles

- One API, one response envelope and one permission model for every client.

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

- Two separate databases for identity and business data, with no cross-database foreign keys (see section 2.8).
- A stateless API tier, so the platform scales out by adding nodes.
- Configuration as data: content, categories, roles and permissions are edited from the Control Panel without a release.

Technical review, point 1. Clarify whether the solution follows a two tier or three tier deployment architecture and whether the presentation layer and the backend layer API / business layer are deployed separately or hosted on the same application server.

SIMF response. Three tier, and the tiers are deployed on separate servers in production.

Presentation tier: SIMF.Web (Blazor SSR) on two web hosts, and SIMF.ControlPanel (Blazor Server) on two admin hosts with session affinity.

Application tier: SIMF.Api on four stateless API hosts. Data tier: SQL Server 2022 in the HSA zone.

The separation is structural, not only physical. Neither presentation project holds a database connection string or an EF Core DbContext; they reference only the shared client libraries and reach data solely through the API over HTTPS 443. A compromise of a presentation host therefore yields no direct database access.

Development and Test run all three sites on a single node, which is the intended footprint for those environments. Figure 1 shows one box per hosting server.

Technical review, point 11. In the diagram Clarify the purpose of the direct connection between the load balancer and the SIMF.ai and whether AI requests are routed directly through the load balancer or through the main application.

SIMF response. That connection has no purpose. It was an error in the v0.07 diagram and it has been removed.

AI requests are made only by the main application. SIMF.Api, through its infrastructure layer, calls the configured AI endpoint. There is no other caller and no other path, whatever provider is configured.

The load balancer carries no AI traffic of any kind. Its role is limited to terminating client TLS, filtering against the OWASP rule set and distributing client requests across the application tiers.

Figure 2 shows the single AI path, drawn from SIMF.Infrastructure to the configured AI endpoint and from nowhere else.

Technical review, point 13. Update the deployment diagram to show the hosting server for each component rather than groping the component under application server and update communication matrix accordingly to the above points.

SIMF response. Done. Figure 1 replaces the previous grouped diagram and shows one box per hosting server, each placed in its zone with its gateway.

Internet zone: attendee mobile device, public website browser, administrator browser, and YouTube. No SIMF server is hosted here.

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

SSA zone: WAF and load balancer (active and standby), API hosts (four), web hosts (two) and admin hosts (two), which are the four server rows in the customer server requirements workbook, plus the internal SMTP relay, the log collector and SIEM, and the controlled egress point. The background jobs need no server of their own: they are hosted services inside the API host.

HSA zone: the two database hosts of the customer server requirements workbook, running the AlwaysOn primary and its replica, and carrying the shared file store.

The Communication Requirements Matrix in section 2.8 has been updated row by row to match, including the removal of the outbound AI row and its replacement by an internal SSA-zone row.

2.2 Modules

Client applications

- Mobile application (Flutter, iOS + Android), the attendee-facing application.
- Control Panel (Blazor Server), the administration application.
- Public Website (Blazor SSR + interactive islands), public content and visitor self-service.

Backend API modules (bounded contexts)

- Authentication and registration; Account and profile.
- Programme, sessions, themes, speakers, presentations, summaries, recordings.
- Bookings and seat reservations; Gates and scanning.
- Exhibition, exhibitors and booths; Sponsors.
- News and media; Archive; Notifications.
- Networking and connections; Meetings (speaker, delegation, business).
- Statistics; System configuration; Organisation profile; Reference data.
- AI (summaries, filtering); Auditing and logs.

Backend layers

- SIMF.Api, the HTTP boundary: endpoints, middleware, authentication, authorisation policies and background workers.

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

- SIMF.Application, use-case orchestration and service abstractions.
- SIMF.Infrastructure, persistence (two DbContexts), storage, e-mail, identity/JWT and audit interceptors.
- SIMF.Domain, entities, aggregates, enums and domain rules; no framework dependencies.

Shared libraries

- SIMF.Common (response envelope, permission catalogue, roles, enums, error codes), SIMF.Contracts (DTOs), SIMF.ApiClient (typed HTTP client), SIMF.Components (shared UI components and design tokens).

Background workers and storage services

- Workers: dormant-account sweep, registration-gate auto-close, session reminders, e-mail dispatch.
- Storage services: avatars, encrypted identity documents, VIP photos, session recordings, speaker presentations, media assets.

Module interaction

All three clients call the same API. The API exposes two route-prefixed surfaces from one process, /api/v1/app/* for the mobile app and the public website, and /api/v1/admin/* for the Control Panel, sharing one response envelope, one error model and one permission system. A separate OpenAPI document is generated per surface so each client team reads only its own contract.

2.3 System Workflow

Visitor registration and approval: the visitor signs up on the website or mobile app , then verifies their e-mail with a one-time code, then completes their profile, then an administrator reviews and approves or rejects in the Control Panel, then on approval the visitor receives a digital QR badge and a notification.

Sign-in with second factor: e-mail + password, then the API issues an e-mailed OTP (visitors) or validates a TOTP code (administrators), then a short-lived access token and a rotating refresh token are issued. Mobile users may enrol a biometric ES256 device key after an OTP step-up.

Seat reservation: the attendee opens a session and reserves a seat (an assigned seat, a random seat, or a one-tap open-seating join). The reservation is confirmed immediately; there is no Control Panel approval step. The seat is held provisionally until the attendee checks in at the hall gate, which confirms it; a sweep shortly before the session releases any hold not checked in. No message is sent on reserving; the app shows the confirmation inline.

Gate scan: a gate operator scans the attendee QR badge, then the API validates the badge, the attendee approval state and the gate's allowed profile types, then the scan is recorded idempotently and an entry / exit outcome is returned.

Live session and Q&A: the attendee opens a live session and plays the configured stream (YouTube, with an HLS or MP4 fallback). A question can be sent before the session (a pre-question) or during it (gated on a hall-arrival record once the session is live); both run the

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

same three stages: an advisory AI filter tags the question, the Scientific Committee approves, hides or escalates it, and the per-session moderator presents the approved questions on stage (order, hide, push to the speaker). Comments follow a separate path: an AI filter, then administrator approval, then the feed.

AI session summary: the session subtitle is imported server-to-server from YouTube (or pasted or uploaded when egress is unavailable) and saved after the team reviews it; the API then calls the configured AI endpoint to draft the summary from that subtitle; the Scientific Committee views the text, edits and approves the draft; an administrator publishes it after the session has started, and attendees read it in the app.

Rating and feedback: rating forms are configurable data; an administrator defines rating types, question groups and questions in the Control Panel without a release. Five types are seeded: App, Session, the overall Forum and the overall Exhibition (each rated once per user) and Day (once per user per programme day). Background workers prompt attendees by attendance: a per-session prompt when a session ends, an end-of-day prompt to those who checked in that day, and an end-of-programme prompt for the Forum, Exhibition and App.

These are the primary system workflows.

Technical review, point 7. *Provide sequence diagrams for the key system workflows, clearly showing the interaction and communication between all relevant system components.*

SIMF response. **Provided at full page size, as Figure 2 and Figure 3.**

Figure 2, the component and interaction view, shows every component: the four client applications, the four internal layers of the SIMF.Api process, the background workers hosted inside it, the shared libraries, the AI service, the e-mail relay, the log collector, the video platform, the two databases and the file store. Each component carries its technology and each call carries its protocol and port.

Figure 3, the system and data flow, shows the same ground as a data flow diagram. The level 0 context view places the platform between the attendee, the administrator and Scientific Committee, the e-mail relay and the video platform. The level 1 view decomposes it into six numbered processes (registration and approval, authentication and access, programme and sessions, bookings and attendance, engagement and feedback, content and notifications) over the three data stores, and every flow that crosses the level 0 boundary reappears in it.

The protocol and port on every line in the figures is taken from the Communication Requirements Matrix in section 2.8, so the diagrams and the matrix cannot disagree.

Figure 1. SIMF production deployment and network architecture. A UML deployment diagram: one node per hosting server, with its zone, its specification and the protocol and port of every path. Answers technical review points 10, 11, 12 and 13.

SIMF production deployment and network architecture

UML deployment diagram. Node specifications are reproduced from the customer server requirements workbook.

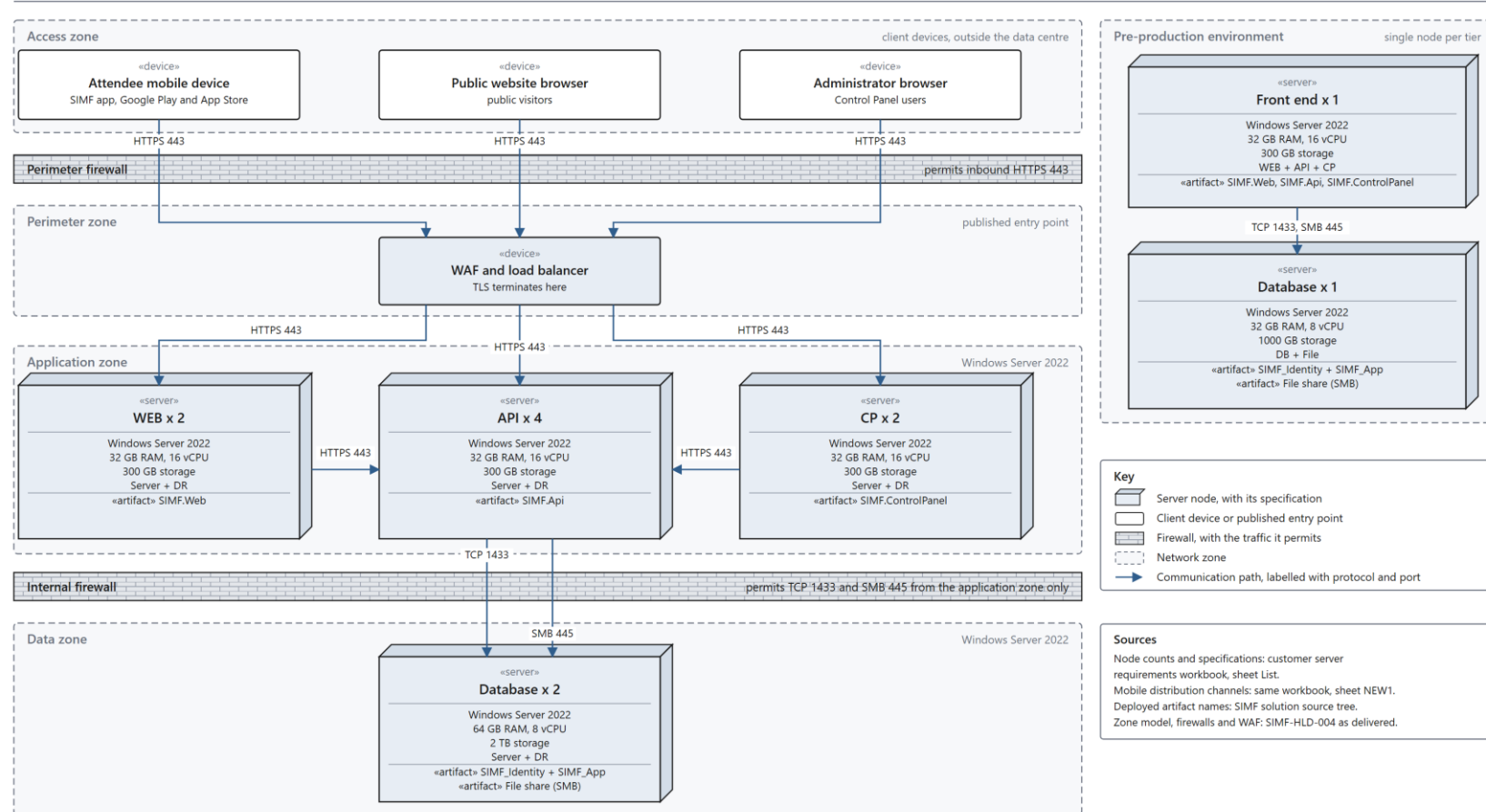


Figure 2. SIMF system components and their interaction. A UML component diagram: every component with its technology, and every call labelled with its protocol. Answers technical review points 1 and 7.

SIMF system components and their interaction

UML component diagram. Every component carries its technology and every call carries its protocol.

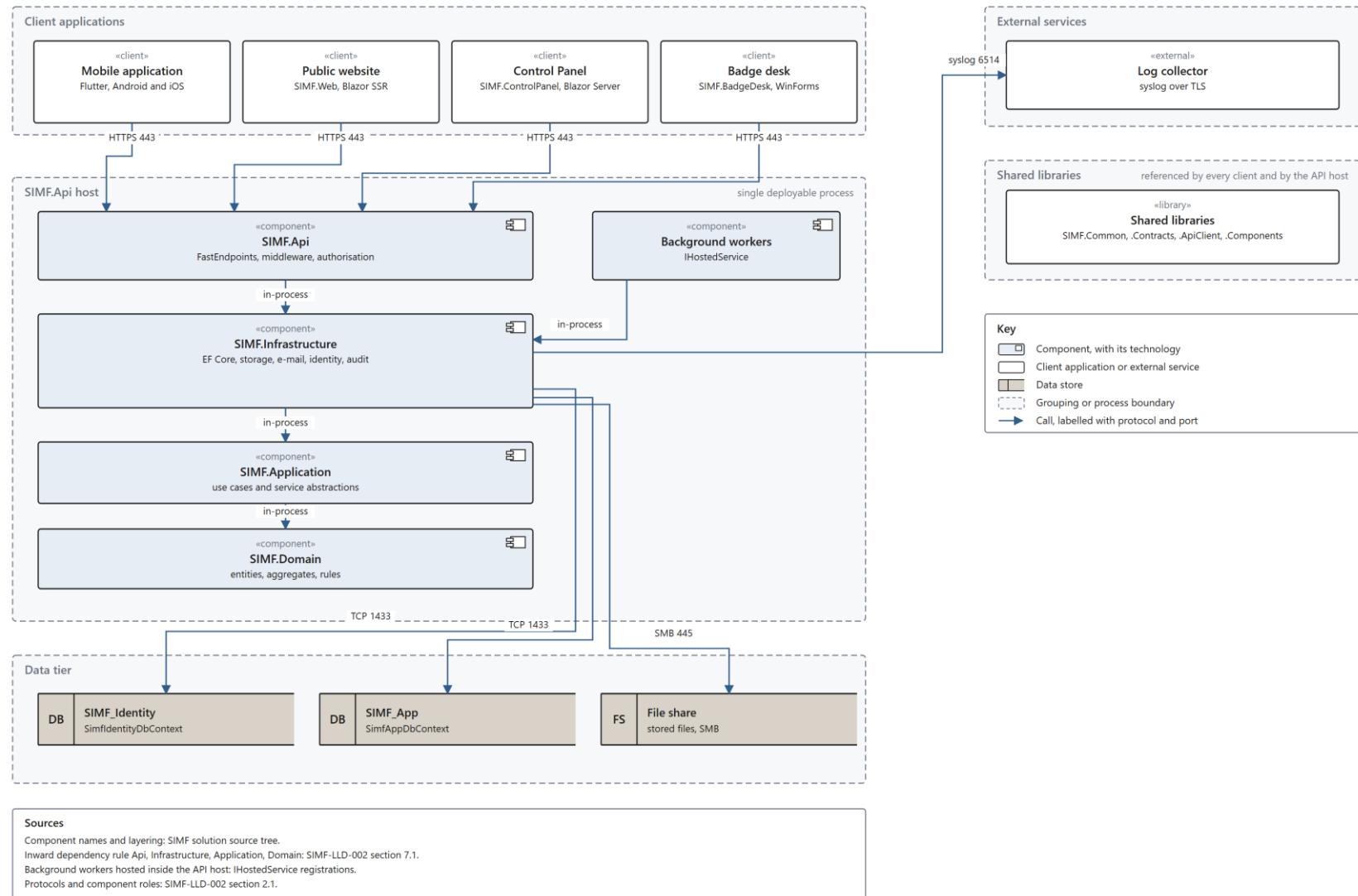
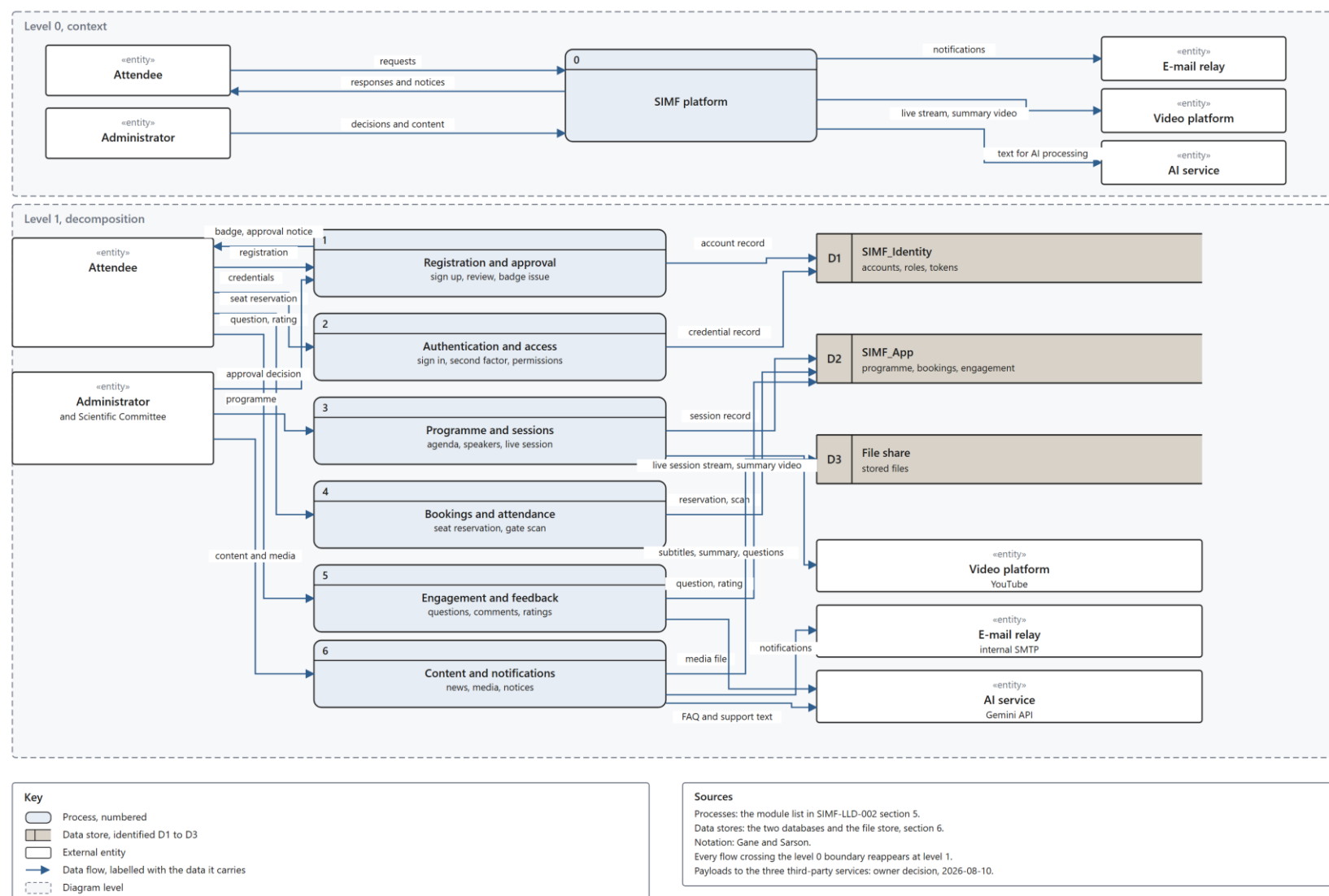


Figure 3. SIMF system and data flow. A data flow diagram in Gane and Sarson notation: a level 0 context view and a level 1 decomposition that balances with it. Answers technical review point 7.

SIMF system and data flow

Data flow diagram, Gane and Sarson notation. Level 1 balances with the level 0 context above it.



1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

2.4 Integration and Interfaces

Internal interfaces

Client to API: HTTPS / REST. Every response uses the ApiResult<T> envelope (success, data, error, meta). Errors carry a machine-readable code and bilingual (English + Arabic) messages. Standard headers: application key, device type, Accept-Language, and Authorization: Bearer <JWT> on protected calls.

API to SQL Server: TCP 1433 to SIMF_Identity and SIMF_App via EF Core. A unit of work touches one database at a time; there are no cross-database transactions or foreign keys.

API to SMTP relay: TCP 587, queued and dispatched asynchronously by a background service (MailKit).

API to Syslog / SIEM: structured Serilog events with a correlation ID.

API to file store: a filesystem store (SMB 445 if a shared store is used when the API is multi-node); database rows hold relative paths, not blobs.

API to the AI endpoint: SIMF.Api is the only caller and the load balancer carries no AI traffic. The endpoint is selected by configuration; an on-premises endpoint keeps the call inside the SSA zone, an external provider would leave through the controlled egress point. No provider is enabled in the delivered configuration. Every invocation is logged and rate-limited per administrator.

Control Panel / Website to API: server-to-server over HTTPS using the shared typed client. Browser sessions hold encrypted authentication cookies and never raw bearer tokens.

External interfaces (outbound only, via the controlled egress point, HTTPS 443)

Artificial intelligence (not an external interface): the AI endpoint listed under Internal interfaces above is a configuration value, and no provider is enabled in the delivered configuration, so no AI request, session content or credential leaves the ministry network.

YouTube caption API: server-to-server subtitle import from youtubei.googleapis.com and www.youtube.com. The returned caption host is re-validated before the second request and a no-redirect HTTP client is used (SSRF hardening). Egress approval is pending; the feature degrades gracefully to paste / upload.

Client-side external interface

YouTube live playback: the attendee device plays the configured stream URL directly. The platform stores only the URL, and this traffic does not traverse the SIMF backend.

No inbound interface is exposed to any external entity.

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

Technical review, point 2. *clarify the role and communication flow of the YouTube integration, including whether the live stream is delivered directly from YouTube to the mobile application and public website , or routed through the application backend.*

SIMF response. The live stream is delivered directly from YouTube to the attendee device. It is not routed through the application backend.

SIMF stores only the stream URL on the Session record and returns it in the session payload. The player in the mobile app and in the website then connects to YouTube itself and receives the video over HTTPS 443.

Consequences, which are deliberate: no video, audio or segment traffic traverses any SIMF server; the platform carries no streaming bandwidth; and SIMF holds no media content. See the device-direct path drawn in Figure 2, from the mobile application to the video platform.

Technical review, point 3. *Also clarify whether the solution only embeds the live stream or uses YouTube APIs to create , manage, or retrieve live stream and caption information.*

SIMF response. SIMF does not create, schedule or manage broadcasts. Those actions are performed by the media team inside YouTube.

SIMF does two things only. First, it embeds playback, using the stored URL. Second, it makes one server-to-server call to retrieve the caption (subtitle) track for a published video id, which feeds the drafting of the session minutes.

The caption call is not essential. If it is unavailable, the administrator pastes or uploads the transcript instead, so no feature is blocked by it.

Technical review, point 4. *clarify the purpose and outbound communication flow between the application backend , the AI provider and the YouTube caption API including the data exchange and authentication method*

SIMF response. These are two different cases, and only one of them is outbound.

Artificial intelligence: in the configuration delivered for the forum no AI provider is enabled, so no AI request leaves the ministry network and no inference is performed at all. Inference sits behind a single abstraction and the provider is a configuration value; the delivered value is a local stub that answers without calling anything. SIMF.Api is the only caller in every case, and the load balancer carries no AI traffic.

Enabling a provider is an explicit ministry decision, and that is the point at which the data question arises. An on-premises inference endpoint keeps every request inside the SSA zone and produces no egress. An external provider would send the fields listed in the table below Point 9 out through the controlled egress point, authenticated with that provider's API-key or bearer-token header, and would require a data-residency decision first. The codebase carries clients for three external providers, each of which accepts a configurable base URL, so the same client addresses an on-premises endpoint without a code change. No on-premises inference service is in place today.

YouTube caption API: this is the only outbound integration in the system. Purpose: import the subtitle track that feeds the session minutes. Data sent: the public YouTube video id, and nothing else. No personal data, no account data and no credential are sent, and the call is unauthenticated because the resource is public.

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

Path: SIMF.Api to the controlled egress point host (both in the SSA zone), which applies an FQDN allow-list and logs every request, then out through the edge firewall. The returned caption host is re-validated before the second request, and the HTTP client does not follow redirects. The full path is the outbound row of the Communication Requirements Matrix in section 2.8.

Technical review, point 9. Clarify the data shared with each external services, including its type, purpose, sensitivity and whether any personal or confidential information is transferred outside the ministry.

SIMF response. No personal or confidential information is transferred outside the ministry by SIMF. There are only two external destinations, and they are both YouTube.

1. YouTube caption API, server-to-server, outbound from SIMF. Data sent: the public YouTube video id only. Purpose: retrieve the subtitle track used to draft the session minutes. Sensitivity: public. Personal data: none. Credential: none.

2. YouTube live playback, from the attendee device, not from SIMF. Data sent: the video id, plus whatever the device's own connection necessarily reveals to YouTube (network address and user agent). Purpose: play the stream. No SIMF account identifier, name, e-mail or booking data is included.

Artificial intelligence sends nothing today, because no provider is enabled. The table below is the complete field-level inventory of what each AI feature would receive once a provider is enabled. If that provider is an on-premises endpoint the data stays inside the SSA zone; if it is an external provider the same fields would leave through the controlled egress point, which is why enabling one requires a data-residency decision first.

Data sent to the AI endpoint once a provider is enabled, by feature.

AI feature	Fields sent once a provider is enabled	Personal data	Destination
Question filter	the question text only	No	Configured AI endpoint
FAQ answer	the visitor question and the published FAQ entries	No	Configured AI endpoint
Assistance	the visitor question and the public programme context	No	Configured AI endpoint
Translation	the source text and the target language	No	Configured AI endpoint
Live translation	the live caption line and the target language	No	Configured AI endpoint
Live sign language	the live caption line	No	Configured AI endpoint
Session minutes	session title, speaker display names, abstract, and the subtitle transcript in English and Arabic	Yes, speaker display names	Configured AI endpoint
Control Panel assistant	the administrator question and the Control Panel context	No	Configured AI endpoint

Hard limits enforced on every call: at most 16 input values, keys of at most 64 characters and values of at most 4000 characters.

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

What cannot be sent, by construction: the caller's identity travels in a separate context object that is never passed into the provider call, so account identifiers, e-mail addresses, national identity or Iqama numbers, passport numbers, badge identifiers and booking records cannot reach the AI service even by mistake.

Session minutes is the only feature that carries any personal data, and that data is the speaker display names, which are already published in the public programme.

No provider is enabled in the delivered configuration, so none of these fields is sent anywhere today. The table states what each feature would send once the ministry enables a provider.

2.5 Error Handling and Logging

Error Handling: a central middleware converts domain and validation exceptions into the standard ApiResponse failure envelope with the correct HTTP status code; clients render the bilingual message. Request validation runs per request shape and returns HTTP 400 with field-level bilingual detail. Invalid states log and throw, there is no silent fallback. Network faults in the typed client are mapped to failed envelopes rather than exceptions. The API refuses to boot in production when a required secret is missing.

Logging: structured logging via Serilog to console and rolling files with 31-day retention, forwarded to the central Syslog / SIEM. Every request carries a correlation ID that is propagated into the logs and both audit trails.

Events logged

- Access and authentication events (sign-in, OTP / TOTP, refresh, sign-out).
- Authorisation denials and rate-limit rejections.
- Security-relevant business events (approvals, configuration changes, gate scans) recorded in the OperationLog trail with actor, subject, source IP, user agent, outcome, error code and correlation ID.
- Row-level data changes, recorded in the RowAudit trail with operation, before / after images, affected columns, actor snapshot and correlation ID.
- System errors and unhandled exceptions.

Both audit trails are append-only at the application level, so the record cannot be rewritten by the application.

2.6 User Interface (UI) Design

UI Overview: three front-ends share one design system and are fully bilingual (Arabic primary / RTL, English secondary / LTR).

- Mobile application (Flutter, iOS + Android), a persistent five-tab shell (Home, Sessions, Badge, Map, Profile) over roughly 34 feature areas: onboarding and splash; sign-in / sign-up / OTP / biometric; profile and registration; programme and session detail; seat picker; digital badge

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

and QR; venue map; live broadcast; AI summary; news; media gallery; archive; booths; sponsors; media partners; comments and questions; networking; contacts (vCard share / scan); my meetings; gate scan (staff); session moderation (moderator); notifications; accessibility; feedback and rating.

- Control Panel (Blazor Server), roughly 12 navigation groups: Overview, People, Access Control, Programme, Scientific Committee, Exhibition, Engagement, Knowledge, Content, Public Relations, Gates and Reference Data. Every list page uses one standard data-grid component (filter, select-all, row checkbox, quiet per-row icon actions) with a shared CRUD framework, so all administration pages behave identically.
- Public Website (Blazor SSR), statically rendered public content (home, programme, visit information) for speed, with interactive islands for the authentication and account flows.

Wireframes and mockups: the approved design, with its per-page node map and page index, is maintained in Figma.

Usability considerations: Arabic-first RTL layout with automatic mirroring; a single design-token source of truth for colour, typography, spacing and radius; flexible responsive widths (the platform is used on phones and tablets); pull-to-refresh on every data screen; accessibility controls on mobile (text size, high contrast, reduced motion); the website targets WCAG AA.

2.7 Operational Model View

SIMF uses four environments, promoted in order with test-gated promotion: Development, Test, Staging and Production.

Development and Test. A single node runs the three application sites and one SQL Server Standard instance, with OpenAPI enabled. This is the right footprint for these environments.

Staging. Mirrors the production topology as a live rehearsal, ready two weeks before launch, and is where the load test runs.

Production. The full architecture of section 2.1: the WAF and load balancer; the API tier (four nodes), the website and admin tiers (two nodes each, with session affinity), and the background worker; and SQL Server 2022 Enterprise in an AlwaysOn Availability Group. Per-tier specifications are the sizing table in section 2.1.

Zone allocation

- Internet, attendees, administrators, and the single outbound external service (the YouTube caption API). No SIMF server runs here.
- SSA Zone, the WAF and load balancer; the API, website and admin tiers, which carry the background jobs in-process; the internal SMTP relay and log collector; and the AI endpoint when an on-premises provider is configured.
- HSA Zone, the two database nodes running the Availability Group, the shared file store and the backups, reached only from the application servers.

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

- A firewall sits at each zone boundary.

Production prerequisites

- Issue a CA-signed TLS certificate and remove the development trust-all setting from the mobile client.
- Open outbound access, through the controlled egress point, to the YouTube caption hosts only. No other outbound destination is required.
- Provision the shared file store and enable session affinity for the website and Control Panel tiers.

Service operations

- The three application sites (API, Control Panel, website) run as IIS sites and application pools. One operations script (deploy/ops.ps1) installs, removes, starts, stops and restarts each site, and reports its status.
- The background workers run in-process in the API application pool, so restarting the workers restarts the API pool; the operations script exposes this as a Workers target, isolated so that only that part of the script changes when the workers move to a dedicated Windows Service.
- Production configuration and every secret are applied as machine-scope, SIMF-prefixed environment variables by per-service scripts (deploy/set-env-api, set-env-cp, set-env-web); the committed templates carry empty values, and the real values are set on the server and never committed. The hosts, protocols and ports are the Communication Requirements Matrix in section 2.8.

Technical review, point 10. Clarify in the diagram the SIEM and SMTP components, their communication paths, hosting locations, and applicable gateways and update the communication matrix accordingly.

SIMF response. Both are internal and both are hosted in the SSA zone. Figure 1 shows the hosting servers named in the customer server requirements workbook, which lists a server for neither, so both are drawn in Figure 2, the component and interaction view, each with its protocol and port.

SMTP relay: an internal relay in the SSA zone, reached from SIMF.Api, which hosts the e-mail queue, over SMTP with STARTTLS on TCP 587. It is the only e-mail path, it is internal, and it does not use the edge gateway; mail is queued and dispatched asynchronously.

Log collector and SIEM: hosted in the SSA zone and receiving syslog over TLS on TCP 6514 from the application hosts. Fifteen Sigma 2.x detection rules are supplied with the system. One point of precision: the application writes structured events to rolling log files, and forwarding those files to the collector is performed by a host log shipper configured at deployment, not by an application sink. It is therefore an operational deployment step, and it is listed as such.

Neither component traverses the edge firewall or any Internet gateway. The Communication Requirements Matrix in section 2.8 has been updated for both.

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

Technical review, point 12. *Clarify the outbound communication path from SIMF.ai to the external services, including the firewall, gateway and network zone . SIMF.ai shouldn't connect directly .*

SIMF response. Agreed, and it does not. No AI provider is enabled in the delivered configuration, so there is no AI egress at all, and no application host except the egress point holds an outbound route. If the ministry later enables an external provider, that traffic would take the same single controlled path as the caption import, never a direct connection from the AI component. The AI endpoint is not a hosting server and so does not appear in Figure 1, which shows servers; it is drawn in Figure 2, which shows components.

The only outbound flow in the system is the YouTube caption import, and its full path is: SIMF.Api (SSA zone) to the controlled egress point host (SSA zone), which applies an FQDN allow-list and logs every request, then through the edge firewall and perimeter gateway to the Internet. No application host other than the egress point holds an outbound route.

One point of precision, so the control is not over-stated: this restriction is enforced at the network layer, by the egress host and the firewall rules. No forward-proxy client is configured in the application code, which means the control is a deployment and network control rather than an application feature. The application requires no change for it to take effect.

2.8 Data Architecture View

Database Architecture: SIMF uses two physically separate SQL Server 2022 databases. The separation is permanent and is itself a security control, it isolates and freezes the identity surface.

- SIMF_Identity, users, roles, permissions, role-permissions, refresh tokens, account and OTP codes, second-factor tokens, TOTP recovery codes, biometric device keys, password history, and per-user notifications.
- SIMF_App, all business data: profiles, programme and sessions, halls and seat reservations, gates and scans, exhibition and booths, sponsors, news, media, archive, networking, meetings, feedback and ratings, venue map, system settings, organisation profile, and the audit tables.

Separation rules (permanent invariants)

- No cross-database foreign keys. A reference from a business entity to a user is a bare GUID (a logical foreign key) resolved on read with a second query, never a database constraint and never a cross-database join.
- No duplicated live data. Identity-owned data is never copied into SIMF_App. The only permitted copies are immutable audit snapshots (the actor display name and e-mail captured at write time) so the audit trail is self-contained.
- No cross-database transaction. A unit of work touches one database at a time.

The two connection strings may address the same instance or separate physical servers, which is what lets the single-server development topology and any future scaled-out production topology share one design.

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

Data Flow: Attendees and administrators reach SIMF over HTTPS. TLS terminates at the load balancer, which routes public pages to SIMF.Web and app and API traffic to SIMF.Api. SIMF.Api authenticates and authorises the caller, runs the use case, and reads or writes the database over TCP 1433. Files are read and written through the file store, e-mail is queued to the SMTP relay, AI inference is performed by the configured AI endpoint when one is enabled, and the outbound caption call leaves through the controlled egress point. Every request carries a correlation ID written to the logs and both audit trails.

Data Storage

- Database: Microsoft SQL Server 2022. Production runs the two database nodes of the customer server requirements workbook as an AlwaysOn Availability Group behind a listener, giving automatic failover. Development and test use a single instance.
- File storage: a shared file store for avatars, identity documents, photos, recordings, presentations and media, encrypted at rest. Database rows hold references, not blobs.

Data Integrity and Validation

- Database constraints: primary keys, foreign keys (within a single database), unique and filtered-unique indexes (for example one active reservation per seat per session) prevent duplication and enforce relational consistency.
- Transaction management: each unit of work is atomic within one database, preventing partial updates.
- Input validation: all input is validated server-side at the API boundary regardless of client validation. Validation rules, database column lengths and UI field limits are kept aligned. EF Core parameterises every query, there is no raw SQL string concatenation.
- Audit trails: every insert, update and delete is captured in RowAudit with before / after images, an actor snapshot and a correlation ID; security-relevant business events are captured in OperationLog. Both are append-only.
- Encryption: PII (national ID / Iqama / passport and mobile numbers) and identity-document images are encrypted at rest; all traffic is encrypted in transit.
- Soft delete: business entities are deactivated rather than physically removed, preserving referential history.

Expected concurrent sessions and throughput: the platform is sized for the three forum days, when the registration surge, live-session concurrency, gate-scan bursts and notification fan-out coincide. The capacity target is about 30,000 concurrent active attendees at peak (about 50,000 registered at a 0.6 peak factor) with headroom; the per-tier sizing that carries it is the table in section 2.1.

The exact concurrent-session and throughput figures are confirmed during staging load testing and recorded in the deployment prerequisites. See also section 2.9 Sizing and Performance View.

Technical review, point 6. Clarify the purpose of the file share storage and specify the type of files and data that will be stored in it.

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

SIMF response. Purpose: to hold binary content that must not be stored in the database and that must be readable by every application node. In the multi-node production topology it is a clustered SMB share in the HSA zone, so any API node can read back what another node wrote.

Database rows hold relative paths, never blobs.

Content is classified into 18 service categories across 4 sensitivity tiers. The categories are: avatar, identity document, VIP photo, speaker photo, speaker presentation, session recording, news image, media-gallery image, media-partner logo, sponsor logo, exhibitor logo, booth logo, company logo, organisation logo, organisation hero video, programme-day image, banner and archive cover.

Four categories are encrypted at rest: avatar, identity document, VIP photo and speaker presentation. Session recordings are deliberately not encrypted at rest, because HTTP range requests (206 Partial Content) require seekable content and the authenticated-encryption mode used is not seekable; they are protected by access control instead.

Access is only ever through the API, which enforces the per-category policy on every read and write. The share is not reachable from any client, from the website or from the Control Panel.

Communication Requirements Matrix

The ports and protocols are the standard values for each flow. IP ranges and VLANs are assigned by the site network team.

Source	Destination	Protocol	Port	Direction	Purpose
Mobile app (Internet)	WAF + Load Balancer	HTTPS / TLS 1.2+	443	Inbound	App API traffic
Public browser (Internet)	WAF + Load Balancer	HTTPS / TLS 1.2+	443	Inbound	Public website traffic
Administrator (Internet)	WAF + Load Balancer	HTTPS / TLS 1.2+	443	Inbound	Control Panel traffic
WAF + Load Balancer	SIMF.Web	HTTPS	443	Internal	Public website rendering (session affinity)
WAF + Load Balancer	SIMF.Api	HTTPS	443	Internal	API to the mobile app (stateless, round-robin)
SIMF.Web / SIMF.ControlPanel	SIMF.Api	HTTPS	443	Internal	Server-to-server typed API client
SIMF.Api	SQL Server (AG listener)	TCP / TDS	1433	Internal	Data access (SIMF.Identity + SIMF.App)
SQL replica to SQL replica	SQL Server (AlwaysOn AG)	TCP	5022	Internal	Availability Group replication
SIMF.Api	SMTP relay	SMTP / TLS	587	Internal	Transactional e-mail dispatch, internal relay, no Internet gateway
All application hosts	Log collector / SIEM	Syslog / TLS	6514	Internal	Centralised structured logging, forwarded by a host log shipper
SIMF.Api	Shared file store	SMB	445	Internal	File store access
SIMF.Api	Controlled egress point	HTTPS	443	Outbound	Outbound caption import, the only outbound flow
SIMF.Api	AI endpoint (configured)	HTTPS	443	Internal	AI inference. No provider enabled in this delivery
Controlled egress point	YouTube caption hosts	HTTPS	443	Outbound	Caption import
Attendee device (Internet)	YouTube	HTTPS	443	Client-side	Live session playback (does not traverse SIMF)

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

IP addresses and ranges are assigned by the site network team.

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

2.9 Solution and Non-Functional Views

Solution Security View

Application Security, authentication: e-mail + password for all audiences. Second factor: e-mailed one-time password for visitors, TOTP authenticator for administrators with single-use recovery codes. Optional biometric sign-in on mobile using an enrolled ES256 device key. SIMF operates its own ASP.NET Core Identity store; there is no Active Directory dependency.

Tokens: short-lived HS256 JWT access tokens (5-minute cap) with rotating refresh tokens and an absolute 24-hour session cap. Token reuse is detected, and a per-user security stamp allows a session to be revoked immediately. The signing algorithm is pinned, so alg:none and algorithm-confusion attacks are rejected.

Authorization: role-based access control with per-page / per-action permissions. Permission codes live in a single catalogue, are seeded idempotently, are baked into the JWT and are enforced on both the API and the Control Panel; Administrator holds a wildcard. Build-time tests fail the build if any Control Panel page or admin endpoint is missing its permission gate, an ungated admin surface is treated as a security defect, not a bug.

Web Application Firewall. A WAF at the edge filters common web attacks (SQL injection, XSS, CSRF), blocks malicious requests before they reach the application, and alerts on suspicious activity, in line with the NCA standard.

Load Balancer. Distributes traffic across healthy nodes, centralises TLS termination, and health-checks each node. The website and Control Panel run with session affinity; the API is stateless and load-balanced round-robin.

Encryption in transit. All traffic is TLS 1.2 or higher, terminated at the load balancer and re-encrypted to the backend.

Encryption at rest. Personal data (national ID, Iqama, passport and mobile numbers) and identity-document images are encrypted with application-level AES-GCM envelope encryption, the key supplied through an environment variable.

Hashing: passwords are hashed by ASP.NET Core Identity; refresh tokens and one-time codes are stored hashed and never in clear text.

Request protection and hardening: multi-dimensional rate limiting, per IP on the authentication bucket, per e-mail on credential endpoints, a global safety cap, and per-administrator on AI calls, with audited rejections; security headers and a Content-Security-Policy; an explicit CORS origin allow-list (never a wildcard); OpenAPI / Swagger disabled by default in production and gated behind Basic authentication when enabled; upload scanning; and secrets supplied only through environment variables with production boot guards.

Audit: two append-only trails, OperationLog for security-relevant business events and RowAudit for row-level before / after images, each carrying an actor snapshot, source IP, user agent and correlation ID.

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

Compliance: aligned to the NCA Secure Application Development Standard, with ECC and OWASP baselines. A documented gap analysis drives the remediation programme.

Owner and operations actions still open: rotate the secrets present in development configuration history; issue a CA-signed certificate and remove the mobile development TLS bypass; enable the identity-lifecycle controls (password expiry / history, dormant-account disable); deploy the WAF; and commission an independent penetration test.

Technical review, point 5. *How users will be authenticated during subsequent logins if passwords are not stored. Also clarify whether the password sent by email is temporary, how it is securely verified and whether users are required to change it upon first login.*

SIMF response. Passwords are stored, but only as a one-way hash. SIMF stores a PBKDF2-HMAC-SHA256 hash with a per-user salt and a work factor (the ASP.NET Core Identity default). The plaintext is never stored and cannot be recovered from the hash.

Subsequent sign-in: the user submits the password, the API applies the same derivation to the submitted value and compares the result with the stored hash. On success a second factor is required, an e-mailed one-time code for visitors or a TOTP authenticator code for administrators. Only then are tokens issued.

No password is e-mailed to a self-registered attendee. The e-mail carries a six-digit verification code, not a password. The code is itself stored hashed, is compared in constant time, expires, and is consumed on first use.

Administrator accounts created by invitation receive a single-use invitation link valid for exactly seven days. The invitee sets their own password when they use it, and the link is then consumed, so no shared or temporary password is ever transmitted.

Forced change is implemented and enforced. When an account carries the PasswordChangeRequired flag, which is set when an administrator rotates a credential or when a password reaches its maximum age, every token-issuing path is blocked (initial password step, second-factor verify, recovery-code verify, one-time-code verify and refresh) until the user sets a new password through the reset flow.

Technical review, point 8. *Clarify the mobile enrolment and authentication flow including the OTP process, secure storage of the ES256 private key on the device, public key registration, device binding, key revocation. And the process flow when the device is lost or replaced.*

SIMF response. Enrolment: the attendee signs up with e-mail and password, verifies the e-mail with a six-digit code, completes the profile, and waits for administrator approval. Ordinary sign-in is password plus an e-mailed one-time code, which is hashed at rest, compared in constant time, time-limited and consumed on first use.

Device-key enrolment: after a successful sign-in, and only after the user passes an operating-system biometric or device-credential prompt, the app generates an ECDSA P-256 key pair on the device. Only the public key is sent to the server, as a SubjectPublicKeyInfo DER structure; it is stored against the account with a device identifier, and that record is the device binding. The server accepts ES256 only and rejects any key it cannot parse as ECDSA P-256.

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

Private-key storage, stated precisely: the private key is held in the platform secure storage service, which is the iOS Keychain (accessible only after first unlock, on this device only) and Android EncryptedSharedPreferences under the Android Keystore-derived master key. It never leaves the device and is never transmitted. It is not yet bound to a hardware secure element; migrating the key into the Android Keystore or StrongBox and the iOS Secure Enclave, with user authentication required at the key itself, is a defined hardening step that does not change the server contract.

Authentication: the server issues a random challenge with a five-minute lifetime. The app signs it with the private key and returns the signature. The server verifies the signature against the registered public key, then clears the challenge with a single atomic conditional update that succeeds only if the challenge is still the one that was issued, so a replayed signature is rejected.

Revocation: the user can disable biometric sign-in in the app and an administrator can revoke the device; the key record is stamped as revoked and every subsequent challenge and verification for it is refused.

Lost or replaced device: the old device key is revoked, which immediately makes it useless. The user signs in on the new device with password plus e-mailed one-time code, then enrolls a new key pair. No key material is exported, backed up or transferred between devices.

Solution Availability View

Database tier. High availability and read scale-out come from the SQL Server 2022 Enterprise AlwaysOn Availability Group.

- A read-write primary and one replica run with synchronous commit and automatic failover, which is the Server + DR pair in the customer server requirements workbook. Both databases run in the group. Development and test use a single node.
- Backups: scheduled backups of both databases and the file store support recovery. Migration order is enforced (App database before Identity) so deployments stay forward-compatible.

Application tier. The API is stateless and load-balanced round-robin. The website and Control Panel are server-interactive and run with session affinity. Adding nodes adds capacity with no redesign.

Load Balancer. Distributes traffic across the nodes to prevent overload and keep service continuous.

- Health checks continuously monitor node health and route traffic only to operational nodes.
- Failover support automatically reroutes traffic when a node becomes unavailable, maintaining uninterrupted access.
- Scalability: additional nodes can be added without affecting existing operations.

Operational availability: /health is a real readiness probe (database reachable, migrations applied) used by the load balancer and monitors to pull unhealthy instances out of rotation. Rollback restores the last known-good binaries, re-checks health and re-runs the smoke test. The three forum days are the critical availability window, and an outage during them cannot be rescheduled.

Solution Management and Monitoring View

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

Syslog / SIEM integration: a centralised structured logging system (Serilog) collects events from all components, the API, the Control Panel, the website and the database tier. It captures authentication events, authorisation denials, access logs, business actions, rate-limit rejections and system errors. Every event carries a correlation ID for end-to-end tracing, and the system integrates with alerting to notify administrators of critical issues.

Audit trails: the OperationLog and RowAudit database trails provide a durable, queryable record of who did what, when, from where and with what outcome, surfaced to administrators through the Control Panel.

Health and performance monitoring: the /health endpoint reports readiness. System health metrics (CPU, memory, response time, throughput) and database query performance are monitored to support proactive capacity planning, performance tuning and threshold-based alerting that detects degradation early.

Usage monitoring: the Control Panel presents event statistics (registrations and approvals, session attendance, seat bookings, gate scans, engagement and ratings) giving insight into peak usage and supporting operational and strategic decision-making during the forum.

Background-services monitor: the scheduled background jobs report a heartbeat to an in-process registry. The Control Panel "Background services" page lists every worker with its state (up, starting, stale or faulted), last run, run and failure counts and last error, refreshing on a short interval; the same registry feeds a "workers" check on /health, so a stalled or faulted job pulls the readiness probe to degraded. Worker logs are written to their own folder, separate from the API request logs, and are viewable through the Control Panel log viewer.

The monitoring and alerting toolchain is selected during deployment planning.

Solution Sizing and Performance View

System scaling and load handling: the platform is built scale-ready so that scaling out is a deployment change rather than a redesign.

- Web tier: SIMF.Web scales horizontally behind the load balancer by adding nodes, with session affinity enabled.
- Backend tier: SIMF.Api is stateless, so nodes are added to absorb registration surges, gate-scan bursts and live-session load. The baseline is four API nodes at 16 vCPU / 32 GB each, which is the figure in the customer server requirements workbook (see the section 2.1 sizing table).
- Database tier: the two-node Availability Group carries the load, and scales vertically (more CPU, RAM and faster storage). Development and test use a single node.

Performance considerations: response time and throughput are addressed structurally rather than by tuning alone.

- Queries are indexed and projected; list endpoints page at source (default page size 20, grid cap 200) rather than filtering in memory.
- The API is stateless, so no session store sits on the request path.
- E-mail is queued and dispatched asynchronously, so SMTP latency never blocks a request.

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

- Live notifications and Q&A use client polling on a bounded interval.

Caching strategy: reference and configuration data (categories, settings, site content) is cached at the application layer to reduce database load, and static web assets are served with cache headers. A distributed cache can be added behind the existing abstractions if load testing calls for it.

Monitoring and auto-scaling: peak-shaped load tests are planned for staging, covering registration surge, live-session concurrency, scan bursts, notification fan-out and mixed steady state. Performance dashboards track system metrics so thresholds can trigger scaling action during peak usage.

Load-test pass/fail thresholds (p95 response time, error rate, concurrent sessions and throughput) are set during staging load testing.

3. Risks and Mitigation Strategies

Security Risk

Potential Impact: unauthorised access to attendee personal data (national ID / Iqama / passport) or to administrative functions; a data breach through an unprotected endpoint; compromise of signing keys or credentials.

Mitigation Strategies: per-page / per-action permission gating enforced on both the API and the Control Panel, with build-time tests that fail the build if a surface is ungated. PII and identity documents encrypted at rest; TLS 1.2+ in transit. A WAF at the SSA-zone edge. Multi-dimensional rate limiting with audited rejections. Secrets supplied only through environment variables with production boot guards. Append-only audit trails.

Alignment to the NCA Secure Application Development Standard, with an independent penetration test before handover.

Outstanding: the secrets present in development configuration history must be rotated, a CA-signed certificate must replace the self-signed certificate, and the mobile development TLS bypass must be removed. These are owner / operations actions and remain open.

Availability Risk (event day)

Potential Impact: the forum runs on fixed dates, so an outage during the three forum days cannot be recovered or rescheduled. Registration surge, live-session concurrency, gate-scan bursts and notification fan-out coincide in that window.

Mitigation Strategies: the event-day architecture, a WAF and load balancer, a stateless multi-node API tier, and the Enterprise AlwaysOn Availability Group for high availability and read scale-out. A readiness probe at /health pulls unhealthy nodes from rotation. Last known-good binaries are retained for rollback, and peak-shaped load testing runs in staging before the event.

Scalability and Performance Risk

Potential Impact: performance degradation at peak. Registration surge, live-session concurrency, scan bursts and notification fan-out coincide, and resource exhaustion could cause slow responses or downtime.

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

Mitigation Strategies: a stateless API tier for horizontal scale-out; client polling on a bounded interval for live data; indexed, projected and server-paged queries; asynchronous e-mail dispatch; and application-layer caching. Load-test to peak shapes in staging and monitor via dashboards, scaling on usage thresholds.

Integration Risk

Potential Impact: the caption import depends on outbound internet access. If egress is not approved, subtitle import does not operate and the administrator pastes or uploads the transcript instead. The AI features are not affected, because inference is performed. A misconfigured egress rule could widen the attack surface, and enabling an external AI provider would add a second outbound destination that needs a data-residency decision first.

Mitigation Strategies: no AI provider is enabled in the delivered configuration, so there is no live dependency on an external AI provider, no provider credential in use and no provider outage exposure. The provider sits behind one abstraction, so an on-premises endpoint can be adopted by configuration when one becomes available. All egress is funnelled through the single controlled egress point with a host allow-list, keeping the egress surface auditable and reviewable against the NCA egress posture. Caption import fails gracefully, administrators can paste or upload a transcript, so no feature is hard-blocked. Every AI invocation is logged and rate-limited per administrator. All integration points, hosts, protocols and ports are documented in the Communication Requirements Matrix (section 2.8).

The caption import requires the outbound egress listed in the production prerequisites (section 2.7). The AI features require no egress at all.

Schedule and Change-Freeze Risk

Potential Impact: the event date is immovable and the platform is frozen before publication, so a defect found after the freeze is expensive and disruptive to correct.

Mitigation Strategies: four-stage promotion (Development, then Test, then Staging, then Production) with no skipping, where a failing gate stops promotion. Trunk-based development with pull-request review, a zero-warnings Release build, and unit, integration and end-to-end test gates in the pipeline. A per-page end-to-end test-case catalogue is maintained as executable regression proof. Dependency vulnerability scanning and SBOM generation run in the pipeline.

Data Integrity and Compliance Risk

Potential Impact: loss or corruption of attendee, booking or scan data; inability to evidence who changed what for a compliance audit.

Mitigation Strategies: the identity and business databases are physically separated with no cross-database foreign keys, transactions or duplicated live data, which isolates and freezes the identity surface. Atomic single-database units of work. Database-enforced keys and filtered unique indexes (for example, one active reservation per seat per session). Soft delete preserves history. Every row change is captured in RowAudit

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

with before / after images, and security-relevant events in OperationLog; both trails are append-only and carry actor, source IP and correlation ID.
The persistence and enum contract surface is under a change freeze with controlled additive lifts.

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

Annex A. Technical review, summary of responses

Every point raised in the technical review of SIMF-HLD-002 (MoD HLD External v0.07) is answered inside the section of this document that owns the subject, not in an appendix. This index gives a one-line summary of each response and the section that carries it in full. Inside those sections each request is reproduced verbatim, in *italic*, above the response. The standalone reply is the companion document SIMF-HLD-004 Response to the Technical Review.

Point	Subject	Response in one line	Answered in
1	Two tier or three tier, and tier deployment	Three tier. Presentation, application and data tiers are separate servers in production.	2.1 Architecture Overview
2	YouTube live stream flow	Delivered directly from YouTube to the device. It is not routed through the backend.	2.4 Integration and Interfaces
3	Embed only, or YouTube APIs	Embed only, plus one caption retrieval call. SIMF creates and manages no stream.	2.4 Integration and Interfaces
4	AI and caption API outbound flow	No AI provider is enabled, so no AI traffic leaves. Only the caption call goes out, carrying a public video id.	2.4 Integration and Interfaces
5	Authentication and e-mailed passwords	Passwords are stored as PBKDF2 hashes. No password is ever e-mailed. Forced change is enforced.	2.9 Solution Security View
6	Purpose and content of the file share	Binary content the database must not hold. 18 categories, 4 tiers, 4 encrypted at rest.	2.8 Data Architecture View
7	Sequence diagrams	Provided. Figure 2 for components and interaction, Figure 3 for the system and data flow.	2.3 System Workflow, Figures 2 and 3
8	Mobile enrolment and the ES256 key	Key pair generated on the device, only the public key registered, challenge signed, revocable.	2.9 Solution Security View
9	Data shared with external services	Only YouTube, and only a public video id. Nothing is sent to an AI provider today.	2.4 Integration and Interfaces
10	SIEM and SMTP in the diagram	Both internal to the SSA zone. SMTP on 587, SIEM on 6514. The matrix is updated.	2.7 Operational Model View, Figure 2
11	Load balancer to AI connection	No such connection. It was a diagram error and is removed. Only SIMF.Api calls the AI endpoint.	2.1 Architecture Overview, Figure 2
12	Outbound path from the AI service	Agreed. No AI egress exists today. Any egress is via the egress point and edge firewall.	2.7 Operational Model View
13	Hosting server per component	Done. Figure 1 shows one box per hosting server, and the matrix is updated to match.	2.1 Architecture Overview, Figure 1

1448/02/02 هـ	تاريخ التطبيق Date Effective	 وزارة الدفاع MINISTRY OF DEFENSE	HLD Form	عنوان النموذج Form Title
2027/07/21 م	رقم النسخة Rev. Number			رمز النموذج Form Code
1	مالك النموذج Form Owner		Apexium	جهة الإصدار Issuer
إدارة التقنية				

Approvals

Technology Expert, Role 1

Signature: _____

Date_____

Technology Head

Signature: _____

Date_____

Technology Director

Signature: _____

Date_____